

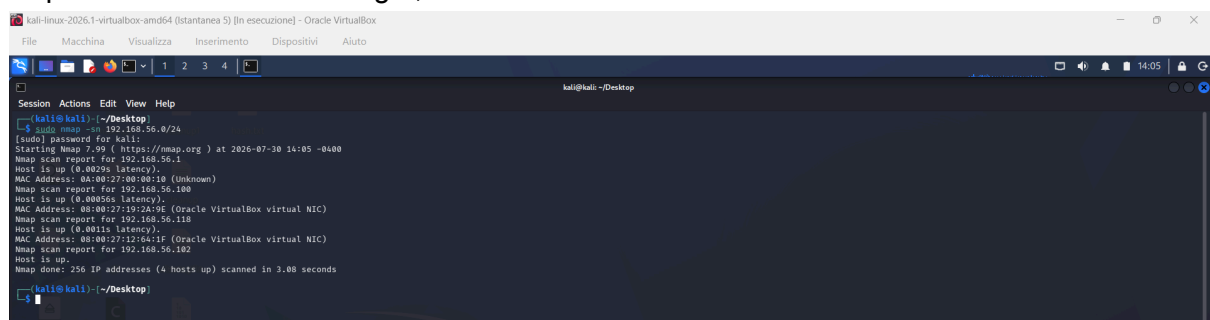
Relazione Tecnica: Penetration Testing su Jangow01

1. Panoramica del Progetto (Executive Summary)

Il presente documento descrive le fasi dell'assessment di sicurezza e del penetration test eseguito sulla macchina virtuale Jangow01. L'obiettivo principale della CTF (Capture The Flag) consisteva nell'effettuare la ricognizione, individuare vettori d'attacco applicativi, stabilire l'accesso al sistema ed eseguire una scalata dei privilegi (Privilege Escalation) per ottenere i privilegi di root e la flag finale.

2. Metodologia e Fasi del Penetration Test

Fase 1: È stato configurato un ambiente virtuale utilizzando VirtualBox, collegando la macchina target jangow01 alla macchina d'attacco Kali Linux tramite rete con host. Per identificare la presenza del target all'interno della rete, è stata eseguita una scansione di scoperta tramite il comando `sudo nmap -sn 192.168.56.0/24` (o sulla sottorete di riferimento) dalla macchina host Kali Linux. Tramite il servizio DHCP e la scansione di rete, è stato acquisito l'indirizzo IP del target, identificato in 192.168.56.118.



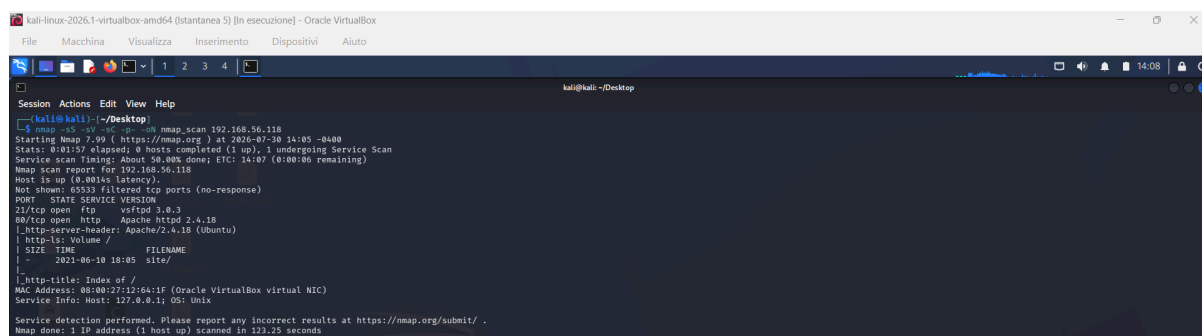
```
kali@kali: ~/Desktop
Session Actions Edit View Help
┌─(kali@kali):~/Desktop
└─$ sudo nmap -sn 192.168.56.0/24
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 14:05 -0400
Nmap scan report for 192.168.56.1
Host is up (0.0029s latency).
NAC Address: 08:00:27:00:00:10 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00056s latency).
NAC Address: 08:00:27:10:2A:9E (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.118
Host is up (0.0011s latency).
NAC Address: 08:00:27:10:2A:1F (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.88 seconds
┌─(kali@kali):~/Desktop
└─$
```

Fase 2: Scansione delle Porte (Port Scanning con Nmap)

È stata eseguita una scansione approfondita delle porte TCP utilizzando lo strumento nmap con il comando:

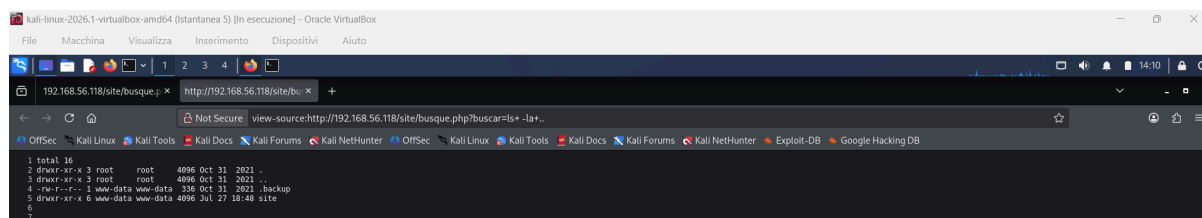
```
nmap -sS -sV -sC -p- -oN nmap_scan 192.168.56.118
```

- **Risultati della scansione:**
- **Porta 21/TCP:** Servizio FTP attivo ([vsftpd 3.0.3](#)).
- **Porta 80/TCP:** Servizio HTTP attivo ([Apache httpd 2.4.18](#)), con directory listing abilitata e presenza di una cartella [/site/](#).



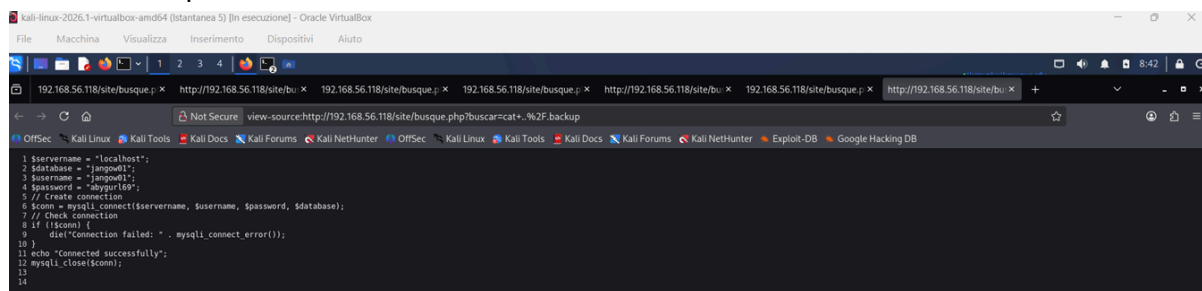
Fase 3: Enumerazione del Servizio Web e Command Injection

- Esplorando l'applicazione web sulla porta 80, è stata individuata una sezione di ricerca denominata "Buscar" (busque.php), il cui parametro GET buscar si è rivelato vulnerabile a Command Injection.
- L'inserimento di payload mirati ha permesso l'esecuzione di comandi di sistema operativo e l'enumerazione dei file locali (tramite comandi come ls -al, ls+ -la+..), rivelando la presenza di una cartella WordPress e di file di configurazione sensibili.



Fase 4: Raccolta Credenziali e Accesso FTP

- Ispezionando il file di backup (.backup), sono state individuate credenziali di accesso valide per il sistema.



- L'utilizzo di tali credenziali ha permesso di effettuare con successo l'accesso autenticato tramite il servizio FTP (porta 21).

- ## Fase 5: Privilege Escalation e Root Access

- **Stabilizzazione della Reverse Shell:** È stata aperta una connessione in ascolto sulla porta 443 tramite Netcat (`nc -lvp 443`) ed è stata sfruttata la vulnerabilità applicativa (tramite la stringa di payload iniettata via browser visibile nello screenshot) per stabilire con successo la reverse shell verso la macchina target.

- **Creazione e Compilazione dell'Exploit:** Una volta ottenuto l'accesso, ci si è spostati nella directory temporanea (`cd /tmp`) e si è provveduto a creare manualmente il file sorgente dell'exploit (`45010.c`) utilizzando il comando `cat` con delimitatore EOF. Il codice è stato successivamente compilato con il compilatore C (`gcc -o exploit exploit.c`).
- **Elevazione dei Privilegi:** L'esecuzione del binario (`./exploit`) ha sfruttato la vulnerabilità del kernel Linux, consentendo di elevare i privilegi dell'utente corrente.

